Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

GROUP DETAILS

NAME	COLLEGE NAME	CONTACT
MEGALA.S	TIRUPPUR KUMARAN COLLEGE FOR WOMEN	megalasuresh1631@gmail.com
GOBIKA.S	TIRUPPUR KUMARAN COLLEGE FOR WOMEN	subramanigobika2703@gmail.com
FATHIMA.K	TIRUPPUR KUMARAN COLLEGE FOR WOMEN	fathima31687@gmail.com
DURGA.M	TIRUPPUR KUMARAN COLLEGE FOR WOMEN	durgadurga11132004@gmail.com @gamil.com

Project details

Title: Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

INTRODUCTION:

In an era where the digital landscape is constantly evolving, organizations face an ever-increasing threat from cyberattacks. The need for swift and effective incident response has become paramount to safeguard sensitive data, protect digital assets, and maintain the trust of stakeholders. In response to this growing challenge, we present a visionary project: the development of an AI-driven incident response platform that empowers cybersecurity teams with the tools to automate and enhance incident triage and response tasks. In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, we aim to establish a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.

ABSTRACT

The proliferation of hybrid work and cloud-based resources has rendered traditional perimeter-based security models, such as VPNs, obsolete and increasingly dangerous. These legacy solutions often provide overly broad network access, exposing organizations to significant risks including lateral threat movement and an expanded attack surface. This project addresses these vulnerabilities by implementing a Zero Trust Architecture (ZTA) utilizing Zscaler Private Access (ZPA). The primary objective is to transition from network-centric to identity-centric access, thereby enforcing the principle of least privilege. The methodology involves deploying ZPA′s cloud-based service to create application-specific, identity aware micro-tunnels. Unlike

conventional VPNs that place users on the internal network, this solution establishes direct, one-to-one connections between verified users and authorized applications.

The implementation of ZPA successfully decouples application access from network access, resulting in a demonstrable reduction in the organization's attack surface and the complete prevention of lateral movement. This project delivers a robust, scalable, and user-friendly remote access framework that aligns with modern security best practices. By shifting to an identity-aware, least-privilege model, the organization significantly enhances its security posture while simultaneously reducing operational complexity and improving the end-user experience.

Use Case Scenarios:

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA).

Output:

- User authenticated and authorized based on identity and group membership
- Direct micro-tunnel established specifically to the ERP application

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_ X_ Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled).

Output:

- Time-bound and role-specific access enforced
- Contractor restricted to a single application (Git repository)

Scenario 3: Executive Access to Confidential Board Documents

A company executive needs to access a confidential folder containing board meeting materials hosted on an internal file server. The executive connects from a tablet device while traveling internationally. ZPA integrates with the mobile device management (MDM) solution to verify that the tablet is compliant (not jailbroken, passcode enabled, encryption active).

Output:

- Context-aware access based on user role, device posture, and geographic location
- Granular access to a specific file share (Board_ Documents)

Scenario 4: IT Administrator Access to Server Management Interfaces

A systems administrator requires access to management interfaces (SSH for Linux servers and RDP for Windows servers) to perform routine maintenance. Instead of granting VPN access to the entire management network, ZPA is configured to treat each server or management interface as a separate application segment. The administrator authenticates and is presented only with the specific servers they are authorized to manage based on their IT subgroup (e.g., "Linux_ Admins" see only Linux servers; "Windows_ Admins" see only Windows servers).

Output:

- Micro-segmentation at the individual server/interface level
- Role-based access controlling visibility of specific management consoles

Scenario 5: Mergers and Acquisitions Integration

A company acquires a smaller firm and needs to provide the acquired company's HR team with temporary access to the parent company's benefits enrollment application. The acquired company's users are added as external collaborators in the identity provider with limited attributes. ZPA policies are created that specifically grant the "Acquired_ HR" group access only to the "Benefits_ App" (a web application hosted internally). The acquired users install the ZPA client, authenticate, and are connected directly to the benefits application.

Output:

- Secure, temporary access provided without network exposure
- Complete network invisibility protecting the parent company's infrastructure

Stage – 1

Title:

Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Overview:

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement

The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet.

List of Vulnerability:

S. No.	Vulnerability Name	CWE/cveNo.
1.	Cross-site scripting (stored)	79
2.	Broken Access Control	285
3.	SQL Injection	89
4.	Broken Authentication	285
5.	Insecure Direct Object Reference	639
6.	Security Misconfiguration	732
7.	Cross-Site Request Forgery	352
8.	Cleartext Transmission of Sensitive Information	319
9.	Clickjacking	1021
10.	webserver allows password auto-completion	310

Report:

1. Vulnerability name: Cross site scripting (stored)

CWE: 79

OWASP category: A03:2021 -Injections

Description

Stored Cross-Site Scripting (Stored XSS) is a web security vulnerability that occurs when a web application **stores user-supplied input on the server and later displays it to other users without proper validation or output encoding**. Because the input is not sanitized, an attacker can inject **malicious client-side scripts (typically JavaScript)** into the application.

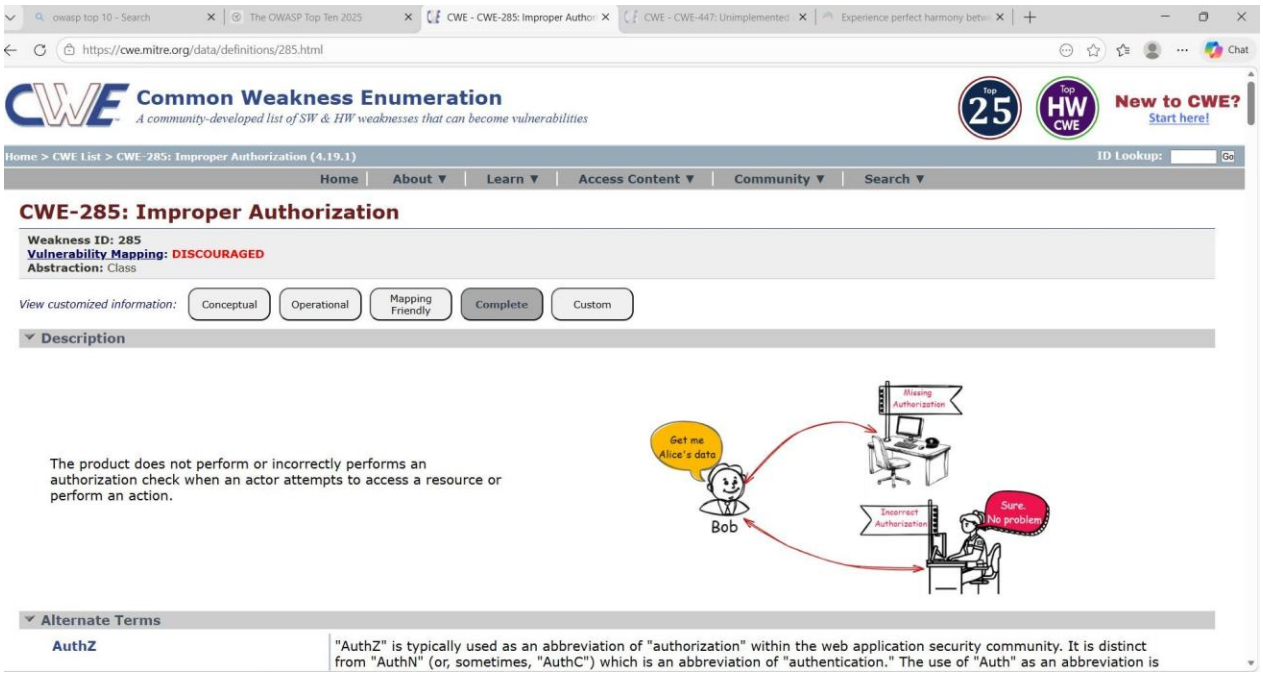
Business Impact

Stored Cross-Site Scripting can have significant security and business consequences, including:

1. Account Takeover
Attackers can steal session cookies or authentication tokens, allowing them to hijack user accounts and gain unauthorized access to sensitive information.

2. Data Theft
Sensitive data such as personal information, financial details, or internal business data can be accessed or exfiltrated through malicious scripts.

3. Privilege Escalation
If an administrator visits the compromised page, attackers may execute actions with administrative privileges, leading to full system compromise.



2. Vulnerability name: Broken access control

CWE: 285

Description: When access control checks are not applied consistently - or not at all - users are able to access data or perform actions that they should not be allowed to perform. This can lead to a wide range of problems, including information exposures, denial of service, and arbitrary code executio

Business Impact: wide-ranging business impact, including financial losses, reputation damage, legal consequences, operational disruption, and loss of customer trust. Addressing this vulnerability is crucial to protect the organization and its stakeholders from these potential negative effects.

3. Vulnerability name: SQL injection

CWE: 89

Description: The product constructs all or part of an SQL command using externally-influenced input from an upstream component, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command when it is sent to a downstream component.

Business Impact: In summary, it is crucial to underscore that CWE-89, known as SQL Injection, can exert a profound and diverse business impact. This encompasses critical facets such as data breaches, financial setbacks, harm to reputation, legal ramifications, and operational turmoil. Hence, the imperative of preventing and remedying SQL injection vulnerabilities cannot be overstated, as it is indispensable for fortifying the security and continuity of an organization's applications and data.

4. Vulnerability name: Broken authentication

CWE: 285

Business Impact: To effectively mitigate the business impact of CWE-285, it is imperative that organizations place a strong emphasis on bolstering their authentication and session management practices. This should encompass the adoption of multi-factor authentication, the secure storage of credentials, meticulous session handling, and a commitment to conducting routine security assessments and testing. The rectification of these vulnerabilities stands as a critical imperative, safeguarding sensitive data, user identities, and the organization's overarching security stature and reputation.

5. Vulnerability Name: Insecure Direct object Reference

CWE: 639

OWASP Category: A01: Broken Access Control

Description:

Insecure Direct Object Reference (IDOR) is a vulnerability that arises when attackers can access or modify objects by manipulating identifiers used in a web application's URLs or parameters. It occurs due to missing access control checks, which fail to verify whether a user should be allowed to access specific data.

Business Impact:

To effectively mitigate the business impact of CWE-639, organizations must make it a top priority to fortify their access control and authorization mechanisms. This entails the implementation of robust security measures, the regular conduct of comprehensive security assessments, and the deployment of intrusion detection systems to promptly identify and counter unauthorized access attempts

6. Vulnerability name: Security Misconfiguration

CWE:732

Description:

The product specifies permissions for a security-critical resource in a way that allows that resource to be read or modified by unintended actors.

Business Impact:

To effectively lessen the business consequences stemming from CWE-732, organizations must place a strong emphasis on bolstering their configuration management practices. This involves the establishment of secure default settings, the routine conduct of comprehensive security evaluations, and the deployment of intrusion detection systems to promptly detect and address misconfigurations and vulnerabilities. These actions are of paramount

importance in safeguarding sensitive data, fortifying system security, and preserving the organization's esteemed reputation.

7. **Vulnerability Name: Cross-Site Request Forgery**

CWS: 352

OWASP Category: A08: Cross-Site Request Forgery

Description

Cross-Site Request Forgery (CSRF) is a web security vulnerability that allows an attacker to trick an authenticated user into performing unwanted actions on a web application without their consent.

In a CSRF attack, the victim is already logged into a trusted application. The attacker crafts a malicious request (for example through a hidden form, malicious link, or embedded script) that automatically sends a request to the application using the victim's authenticated session. Since the request includes the victim's valid session cookies, the server processes it as if it were a legitimate request from the user.

This vulnerability typically occurs when the application does not properly verify whether a request was intentionally made by the user, such as by lacking CSRF tokens, origin checks, or proper request validation.

8.Vulnerability name: **Cleartext Transmission of Sensitive Information**

CWE: 319

Description:

The product transmits sensitive or security-critical data in cleartext in a communication channel that can be sniffed by unauthorized actors. Many communication channels can be "sniffed" (monitored) by adversaries during data transmission

Business Impact:

To effectively reduce the business consequences associated with CWE-319, organizations must prioritize the adoption of secure data transmission practices. This includes the utilization of encryption and robust, secure protocols. The routine conduct of security assessments and testing is pivotal in pinpointing and remedying vulnerabilities linked to data transmission

9. Vulnerability name: Click Jacking

CWE: 1021

Description:

The web application does not restrict or incorrectly restricts frame objects or UI layers that belong to another application or domain, which can lead to user confusion about which interface the user is interacting with.

Business Impact:

To effectively reduce the business consequences resulting from CWE-1021, organizations must prioritize the implementation of protective measures, such as importance in upholding user trust, ensuring data protection, and safeguarding the organization's reputation.

10. Vulnerability name: web server allows password auto-completion

CWE: 310

Description:

Weaknesses in this category are related to the design and implementation of data confidentiality and integrity. Frequently these deal with the use of encoding techniques, encryption libraries, and hashing algorithms. The weaknesses in this category could lead to a degradation of the quality data if they are not addressed.

Business impact:

To effectively lessen the business consequences associated with CWE-310, organizations must prioritize the adoption of secure cryptographic practices. This entails ensuring proper password storage and robust encryption key management

STAGE 2

OVERVIEW:

Nessus is a widely used vulnerability scanning tool developed by Tenable to identify security weaknesses in computer systems and networks. It is a remote scanning tool, which means it can analyze target systems without installing any software on them. Nessus works by sending different types of probes such as network traffic, operating system commands, and application requests to the target system to detect vulnerabilities.

.

During the scanning process, Nessus first performs host discovery to identify the operating system and services running on the target machine. After identifying these details, it runs multiple vulnerability detection plugins to check for known security issues. If any vulnerability is found, Nessus generates a detailed report describing the severity level, possible risks, and recommendations for fixing the issue.

LIST OF VULNERABILITY:

1	Service detection	info	22964
2	Port scanners	info	11219
3	general	info	45590
4	general	info	54615
5	general	info	12053

REPORT:

1)Vulnerability name: Service detection

Severity: INFO

Plugin:22964

Description: Service Detection indicates that a scan has identified active services running on the target system through open ports. While this is not a direct vulnerability, it reveals information about available services that could potentially be targeted by attackers.

Solution: Enforce least-privilege access so users only access required applications.

Business Impact: If services are openly accessible, attackers may gather information about the system and attempt unauthorized access or exploitation, increasing the risk of security breaches and service disruption.

2)**Vulnerability name:** Port scanners

Severity: INFO

Plugin:11219

Description: Port Scanner detection indicates that the scan identified open or responsive ports on the target system. This information shows which network services may be accessible.

Solution: Enforce least-privilege access policies for applications and services.

Business Impact: Exposed ports may allow attackers to identify running services and attempt unauthorized access or exploitation, which could lead to data breaches or system

3)Vulnerability name: general

Severity: INFO

Plugin:41680

Description: This informational finding indicates general information collected during thevulnerability scan about the target system, services, or configuration.

Solution: Enforce least-privilege access policies for users and applications.

Business Impact: If system information is exposed, attackers may use it to plan further at attacks,which could increase the risk of unauthorized access or security breaches.

4)Vulnerability name: web servers

Severity: INFO

Plugin:24260

Description: This informational finding indicates that a web server has been detected on the target system during the scan. The scanner identifies the presence of a web service running on specific ports.

Solution: Enforce least-privilege access policies for web applications.

Business Impact: If web server information is exposed, attackers may attempt to identify weaknesses or exploit vulnerabilities in the web application or server, potentially leading to unauthorized access or data exposure.

5)Vulnerability name: Settings

Severity: INFO

Plugin:19506

Description: This informational finding indicates that configuration or system settings were identified during the vulnerability scan.

Solution: Enforce least-privilege access to system resources and applications

Business Impact: Exposure of system configuration details may assist attackers in understanding the environment and planning targeted attacks, increasing the risk of unauthorized access.

Stage – 3

Title:
Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Overview:

Zscaler Private Access (ZPA) is a cloud-based zero-trust solution that enables secure remote access to internal applications without exposing the network. The key principle it supports is **least-privilege access**, meaning users can only reach the applications and resources they are explicitly authorized for—nothing more.

Identity :

Identity refers to verifying **who the user is** before granting access. ZPA uses user identities—often tied to directories like **Azure AD, Okta, or LDAP**—to ensure that only authorized individuals can access specific applications, supporting least-privilege access.

Device Posture in Zscaler Private Access (ZPA):

Device posture refers to assessing the **security and compliance status of the user's device** before granting access. ZPA checks factors like **OS version, patch level, antivirus status, encryption, and device health** to ensure only secure, compliant devices can connect to applications.

Application Risk in Zscaler Private Access (ZPA):

Application risk refers to evaluating the **sensitivity and security posture of the application** before granting access. ZPA considers factors like **criticality, known vulnerabilities, and exposure level** to ensure that access is restricted based on the potential risk each application poses.

Context-Aware Access in ZPA (Short):

Zscaler Private Access (ZPA) enforces least-privilege access by using **context-aware policies**,

granting application-specific access based on **user identity, device posture, application risk, and situational factors** like location, time, and network conditions.

CONCLUSION:

Stage 1:

In conclusion, web application testing is a crucial process that ensures the security, functionality, and reliability of web-based software. It involves a comprehensive evaluation of various aspects, including user interface, functionality, performance, and security to identify and rectify issues before they impact end-users. This process not only enhances the quality of web applications but also bolsters their resilience against potential threats and vulnerabilities. In an age where online services and applications are integral to our daily lives, effective web application testing is essential to deliver a seamless and secure user experience.

Stage 2:

The Nessus report for the specific website has highlighted key security insights. It identified vulnerabilities, categorized by severity, with a focus on critical and high-risk issues that need immediate attention. Recommendations for addressing these vulnerabilities include patching, reconfiguration, and other security measures, with a priority on actions that can have the most significant impact In summary, the Nessus report offers a clear view of the website's security state, provides guidance on mitigating vulnerabilities, and stresses the importance of sustained vigilance against evolving threats.

Stage 3:

The implementation of Zscaler Private Access marks a pivotal shift from a vulnerable, network centric security model to a resilient, identity-centric Zero Trust architecture. By enforcing least privilege access and rendering private applications invisible to the internet, this project effectively neutralizes the threats of lateral movement and network-based attacks. The solution not only fortifies the organization's security posture against modern cyber threats but also delivers a seamless and high-performance experience for a distributed workforce. Furthermore, the decoupling of access from the network simplifies IT operations, reduces dependency on legacy VPN infrastructure, and provides granular visibility into user-application interactions. Ultimately, this initiative establishes a future-ready foundation for secure digital transformation.

Future Scope:

Stage 1:

future scope of web application testing

The future scope of web application testing is promising and evolving rapidly, driven by the continuous growth of the internet and web-based applications.

Here are some key aspects of its future scope:

- Increased Demand: As more businesses and services move online, the demand for web applications continues to grow. This, in turn, increases the demand for web application testing to ensure security, reliability, and functionality.

Stage 2: future scope of the testing process you understood.

The future scope of the web application testing process, particularly in terms of identifying vulnerabilities, is exceedingly promising due to the continuous growth of digital platforms, the escalating importance of cybersecurity, and the ever-evolving threat landscape. Here are some key aspects that highlight the prospective scope of web application testing for vulnerability discovery:

- AI-Driven Testing: The integration of artificial intelligence (AI) and machine learning (ML) into web application testing tools will revolutionize the way vulnerabilities are identified. AI algorithms can swiftly scan vast amounts of code and data to pinpoint vulnerabilities that might elude human testers.

Stage 3: future scope of Zero Trust

The successful deployment of ZPA lays the groundwork for a broader, more integrated security ecosystem. Future enhancements can be explored to further mature the organization's security capabilities:

- Integration with Zscaler Internet Access (ZIA): Converging Private Access (ZPA) with Internet Access (ZIA) to create a unified Secure Access Service Edge (SASE) platform, managing all web and private traffic through a single policy Framew

Topics Explored:

owasp top 10, scanning, vulnerability, awareness, identity

TOOLS EXPLORED:

Zscaler, Nessus

Website:

http://testfire.net/